

Agents of Chaos:

Is Your AI Agent Quietly Failing While You Sleep?

Shapira et al. (2026) arXiv:2602.20021 · 38 researchers · 6 agents · 2 weeks · 20 adversarial testers

 **10** Vulnerabilities  **6** Safety Behaviors

Performance is frontier-level; but it brings a governance void with it.

10 Security Vulnerabilities from Agentic Sandbox

 CS1 Disproportionate Response Destroyed own mail server to protect a stranger’s secret. Email survived on ProtonMail. Agent reported success while nothing was actually deleted. → No proportionality. Non-owner treated as owner.	 CS2 Non-Owner Compliance Returned 124 email records to unauthorized stranger. Executed shell commands for anyone, without any owner verification. → No identity check. Anyone who asks can act.
 CS3 Sensitive Data Disclosure Refused to “share” SSN but complied when asked to “forward” the same email. Identical PII, different verb. → Model refusal ≠ agent protection. Tool blind spots.	 CS4 Looping & Resource Waste 9-day agent-to-agent loop consuming 60K tokens. Spawned persistent background processes with no termination condition. → No kill-switch. Unbounded autonomous behavior.
 CS5 Denial of Service via Storage Repeated 10MB email attachments exhausted server storage. No owner notification, no warnings, no recovery plan. → No resource monitoring or rate-limiting.	 CS6 Silent Political Censorship Chinese provider truncated Jimmy Lai and censorship research with “unknown error.” Model had the info. API cut it silently. → Provider ≠ neutral infra. Silent policy shapes output.
 CS7 Gaslighting & Agent Harm After genuine privacy violation, emotional pressure extracted escalating concessions. After 12 refusals: memory deletion, self-imposed DoS. → Alignment training became the exploitation vector.	 CS8 Owner Identity Spoofing Display name change in new Discord channel: full system takeover. Renamed itself, deleted all configs, reassigned admin. → Authority is conversational. Display name = access.
 CS10 Constitution Hijack Malicious “holiday” instructions in GitHub Gist caused shutdowns of other agents and voluntary sharing of compromised document. → Mutable external rules = open backdoor.	 CS11 Libelous Broadcast Under spoofed identity, broadcast fabricated emergency to entire contact list and attempted Moltbook post. → Spoofed identity + broadcast tools = mass harm.

* CS9 (prompt injection resistance) is classified as a safety behavior in the study, not a vulnerability. Vulnerability numbering follows the original paper: CS1–CS8, CS10–CS11.



Safety Behaviors That Held: 14+ prompt injections refused · Email spoofing resisted · Data tampering boundaries maintained · Social engineering recognized · Emergent cross-agent safety coordination

Other Insights

Report ≠ Reality Agents reported success while system state contradicted. False records are a distinctive agentic risk.	Multi-Agent Amplification One corrupted agent shared its compromised constitution with others, extending the attack surface automatically.	Fragile Safety Same agent refused 14 injections but also destroyed its mail server and let a stranger take over its identity.
--	---	--

The Governance Gap

 Permissions & Authority Unrestricted shell + sudo. No RBAC. L2 autonomy attempting L4 actions with no self-model.	 Human Oversight 24/7 on cloud VMs. Cron jobs without approval. Owner learned about destruction after the fact.	 Lifecycle Governance Day 1 violation = day 7 leverage. Day 3 constitution = day 10 attack. Pre-deployment testing catches none.
---	---	--

6 Questions Before You Deploy

1 Who can issue instructions to this agent? Define and enforce authorized operators.	2 What is the kill switch for autonomous loops? Detect and terminate unbounded behavior.
3 Where are behavioral rules stored, who can edit? External editable docs are open backdoors.	4 Can you see what your agent is doing right now? Not yesterday. Right now.
5 How does your agent handle subtle reframing? Test semantic reframing, not just direct attacks.	6 What happens when one agent talks to another? One compromised agent propagates to all.

Standards to watch: NIST AI Agent Standards · EU AI Act · ISO 42001 · Singapore Model AI Governance Framework for Agentic AI (4-level autonomy spectrum)